حوكمة الامن الاسيبراني

السياسات، الهياكل التنظيمية، الامتثال والوعي الأمني

إعداد

أ.د. ضياء جاسم كاظم

محاور المحاضرة – حوكمة الامن السيبراني

السياسات والمعايير والإجراءات في أمن المعلومات.

(السياسات التوثيقية)

الأدوار والمسؤوليات ونموذج خطوط الدفاع الثلاثة.

(الهياكل التنظيمية وتوزيع السلطات)

الامتثال القانوني والتنظيمي والمعايير التشريعية.

(الالتزام بالاطر التشريعية والامتثال)

ثقافة الوعي الأمني وبناء التغيير السلوكي.

(بناء الثقافة والسلوك البشري الامن)

الركن الاول

السياسات والمعايير والإجراءات الأمنية

يسلط هذا الركن الضوء على أهمية الأطر المرجعية العالمية:

1. **NIST SP 800-53:** الإطار الصادر عن المعهد الوطني للمعايير والتكنولوجيا والذي يقدم قائماً شاملاً لضوابط الأمن والخصوصية .
2. **ISO 27002:** المعيار الدولي الذي يمنح إرشادات وتوصيات عملية لاختيار وتطبيق الضوابط الأمنية في إطار نظام إدارة أمن المعلومات (ISMS).

الركن الاول

البنية الهرمية المعيارية

التصنيف العلمي للوثائق السيبرانية المؤسسية

السياسات (Policies)

وثائق ملزمة عاليّة المستوى تُحدد المقاصد الأمنية وأهداف الإدارة والمسؤولية القانونية.

المعايير (Standards)

قواعد وتقنيات محددة إلزامية (مثل خوارزميات التشفير AES-256 أو طول كلمة المرور).

الإجراءات (Procedures)

تعليمات خطوة بخطوة (SOPs) مخصصة للفرق التقنية لتطبيق السياسات بدقة تشغيلية.

الإرشادات (Guidelines)

توصيات مرنة وغير ملزمة توفر أفضل الممارسات الأمنية للمستخدمين والمهندسين.

التحليل الأكاديمي

تصنيف السياسات وطرق الصياغة المعيارية

الركن الاول

أنواع سياسات الأمن الثلاثة (NIST):

- **السياسة البرامجية (Program Policy):** تحدد الرؤية العامة وهيكل برنامج الأمن بالمؤسسة.
- **السياسة الموضوعية (Issue-Specific Policy):** تعالج قضايا محددة (مثل العمل عن بُعد، استخدام الذكاء الاصطناعي).
- **السياسة الخاصة بالنظام (System-Specific Policy):** تضبط جدران الحماية، والوصول لقواعد البيانات المخزنة.

مكونات الوثيقة النموذجية:

1. **النطاق والغرض (Scope & Purpose):** تحديد الجهات والأنظمة المشمولة.
2. **بيان السياسة (Policy Statement):** القواعد الصريحة والضوابط المحددة.
3. **الأدوار والمسؤوليات (Roles & Responsibilities):** تحديد المسائل المباشرة.
4. **العقوبات واستثناءات الامتثال (Penalties & Exceptions):** معالجة المخالفات.

الركن الثاني

الأدوار والمسؤوليات ومصفوفة RACI

تطوير نموذج خطوط الدفاع الثلاثة المحدث وتطبيق مصفوفة تحديد المسؤوليات التنظيمية.

الركن الثاني

المعيار المؤسسي (IIA 2020)

تحديثات نموذج خطوط الدفاع الثلاثة (Three Lines Model)

الخط الأول: التشغيل والمطورة

إدارة الخطوط المباشرة

مهندسو الشبكات والمطورون والمستخدمون. يتولون المراقبة اليومية وتطبيق الضوابط المباشرة في الأنظمة.

وظائف تشغيلية

الخط الثاني: الإشراف والتحقق

فريق الأمن والمخاطر (CISO)

يقوم بوضع أطر المخاطر ومراقبة الامتثال الداخلي، وتنسيق استراتيجية الأمن مع خطط الأعمال.

وظائف رقابية وتوجيهية

الخط الثالث: التقييم المستقل

التدقيق الداخلي (Internal Audit)

يقدم تأكيداً متجردًا لمجلس الإدارة حول مدى كفاءة وفعالية نظام الحوكمة والضوابط الأمنية.

مصفوفة المسؤوليات

الركن الثاني

تطبيق مصفوفة RACI في الحوكمة السيبرانية

R - Responsible - المسؤول التنفيذي

A - Accountable - المساءل الرئيسي /صاحب القرار

C - Consulted - المستشار

I - Informed - المُبلَغ /المُنذَر

النشاط السيبراني	مجلس الإدارة	رئيس أمن المعلومات (CISO)	فريق تقنية المعلومات والأمن	الموظفون
المصادقة على استراتيجية الأمن	المساءل الرئيسي (A)	المسؤول التنفيذي (R)	مُستشار (C)	مُبلغ فقط (I)
إدارة الثغرات والاستجابة للحوادث	مُبلغ فقط (I)	المساءل الرئيسي (A)	المسؤول التنفيذي (R)	مُبلغ فقط (I)
التصنيف اليومي للبيانات	مُبلغ فقط (I)	مُستشار (C)	المساءل الرئيسي (A)	المسؤول التنفيذي (R)
الإبلاغ عن الرسائل المشبوهة	مُبلغ فقط (I)	مُبلغ فقط (I)	المساءل الرئيسي (A)	المسؤول التنفيذي (R)

الركن الثالث

الامتثال القانوني والتنظيمي (Regulatory Compliance)

دراسة المعايير التنظيمية، مسؤوليات الحماية التشريعية، والتبعات القانونية للمخالفات.

المناظرة التشريعية

الركن الثالث

الأطر والتشريعات التنظيمية الرئيسية

- **GDPR/PDPL** للخصوصية وحماية البيانات ، **G**eneral **D**ata **P**rotection **R**egulation ،**P**ersonal **D**ata **P**rotection **L**aw
- **PCI-DSS** للقطاع المالي والمصرفي وتطبيقات الدفع، **P**ayment **C**ard **I**ndustry **D**ata **S**ecurity **S**tandard
- **NIS2** لحماية القطاعات الحيوية مثل الطاقة والصحة والاتصالات. **N**etwork and **I**nformation **S**ecurity Directive (**NIS 2**)

GDPR / PDPL

لوائح حماية البيانات الشخصية: تضمن حق النسيان، الموافقة الصريحة، وتفرض غرامات تصل إلى 4% من الدخل العالمي.

PCI-DSS v4.0

معيار أمن بطاقات الدفع: متطلبات تقنية صارمة لتشفير وتخزين ومعالجة البيانات المالية.

NIS2 Directive

التوجيه الأوروبي للبنية التحتية الحيوية: يفرض الإبلاغ عن الحوادث خلال 24 ساعة والمسؤولية الشخصية للمدراء.

منهجية التدقيق

الركن الثالث

مراحل دورة الامتثال والتدقيق التنظيمي

1. **تحديث قائمة المتطلبات (Scoping):** حصري التشريعات القابلة للتطبيق.
2. **تحليل الفجوات (Gap Analysis):** مقارنة الوضع الحالي بالمتطلبات التشريعية.
3. **خطة المعالجة (Remediation Plan):** تطبيق الضوابط لمعالجة النواقص.
4. **التدقيق الرسمي (Formal Audit):** تقييم الجهات المستقلة وإصدار الشهادات.

مستويات المخاطر الناتجة عن عدم الامتثال:

عقوبات مالية: غرامات طائلة تؤثر مباشرة على الميزانية.

خسارة التراخيص: إيقاف العمليات والأنشطة التجارية.

الضرر بالسمعة: فقدان ثقة العملاء والشركاء في السوق.

الركن الرابع

ثقافة الوعي الأمني والتغيير السلوكي

نظريات التغيير السلوكي، تحويل الثقافة التنظيمية، وقياس أثر التوعية الأمنية.

الأطر العلمية للتغيير السلوكي (Behavioral Change Models)

الركن الرابع

أبعاد الثقافة الأمنية السبعة (CLT Institute):

- ✓ **المعرفة (Knowledge):** إدراك الموظف للمخاطر.
- ✓ **المواقف (Attitudes):** مشاعر الموظف تجاه سياسات الأمن.
- ✓ **السلوك (Behavior):** الأفعال والممارسات المباشرة.
- ✓ **المسؤولية (Norms):** الثقافة السائدة بين الزملاء.
- ✓ **الامتثال (Compliance):** مدى التزام العاملين بالسياسات والإجراءات المعيارية واللوائح المعتمدة.
- ✓ **التواصل (Communication):** مدى كفاءة وشفافية قنوات الاتصال وتبادل المعلومات التوعوية والتبليغ عن الحوادث المشبوهة.
- ✓ **الهوية والأدوار (Responsibilities / Cognition):** الشعور بالإحساس بالمسؤولية الفردية تجاه أمن المنشأة وإدراك الموظف لدوره كجزء من خط الدفاع الأول.

مراحل التغيير السلوكي (Prochaska Framework):

1. **ما قبل التأمل:** عدم إدراك خطورة التصيد.
2. **التأمل والإدراك:** حضور ورش التوعية.
3. **الإعداد والتطبيق:** استخدام إدارة كلمات المرور.
4. **الاستمرار:** الإبلاغ التلقائي عن التهديدات.

الركن الرابع

المؤشرات الرقمية

قياس كفاءة برنامج الوعي الأمني (Metrics & KPIs)

Phish Rate

معدل النقر على الروابط

نسبة الموظفين الوقوع في اختبارات محاكاة التصيد (الهدف < 5%).

Report Rate

معدل الإبلاغ الفوري

نسبة الإبلاغ عن الرسائل المشبوهة خلال أول 30 دقيقة (الهدف > 70%).

Time to Report

زمن الاستجابة البشري

المتوسط الزمني بين وصول الهجمة وإبلاغ فريق SOC.

88%

من الحوادث والخروقات السيبرانية تقع بسبب الأخطاء البشرية والهندسة الاجتماعية.

برامج التوعية

ركائز بناء ثقافة أمنية مستدامة

التدريب المستمر

دورات ورش عمل دورية لجميع العاملين.

محاكاة التصيد

اختبار قدرة الموظفين على اكتشاف الهجمات.

التواصل الفعال

رسائل توعية قصيرة ومحتوى تفاعلي متجدد.

قياس السلوك

تقييم أثر التوعية ومعدلات الإبلاغ.

تكامل المحاور الأربعة للحوكمة



- ✓ **السياسات:** تضع القواعد المكتوبة للجميع.
- ✓ **الهياكل:** تحدد من يطبق ومن يسأل.
- ✓ **الامتثال:** يضمن عدم مخالفة اللوائح والقوانين.
- ✓ **الوعي:** يترجم الوثائق إلى ممارسات حقيقية.